

Лекция 11

Угрозы безопасности информации на сетевом уровне модели OSI

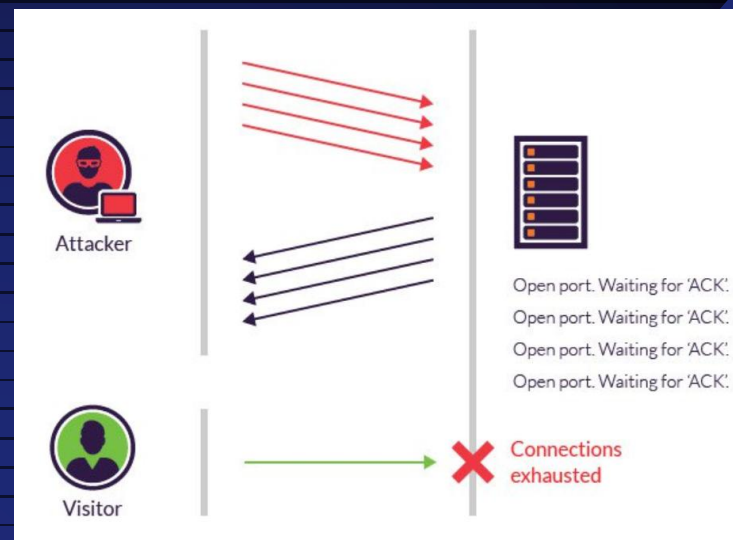
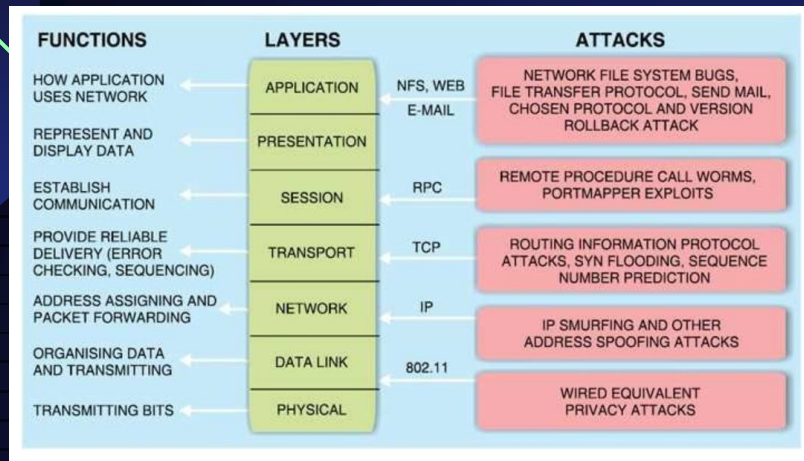


Учебные вопросы:

1. Угрозы безопасности уровня 4 модели OSI.
2. TCP-атаки.
3. Land-атака.
4. UDP-атаки.
5. Атаки сканирования портов TCP и UDP.

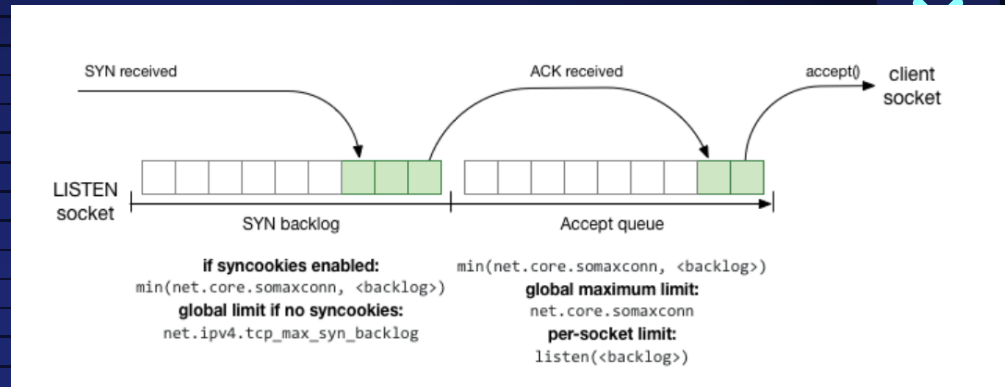
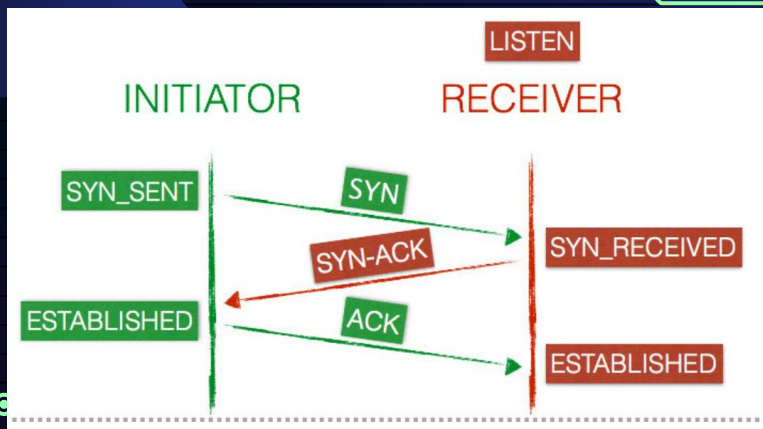
Дополнительный материал:





Угрозы безопасности уровня 4 модели OSI. TCP и UDP - транспортные протоколы уровня 4 модели OSI, обеспечивающие транспортировку данных, скорость и надёжность. TCP сложнее, так как ориентирован на соединение с механизмом управления потоком, тогда как UDP проще, не требует соединения и не имеет такого механизма.

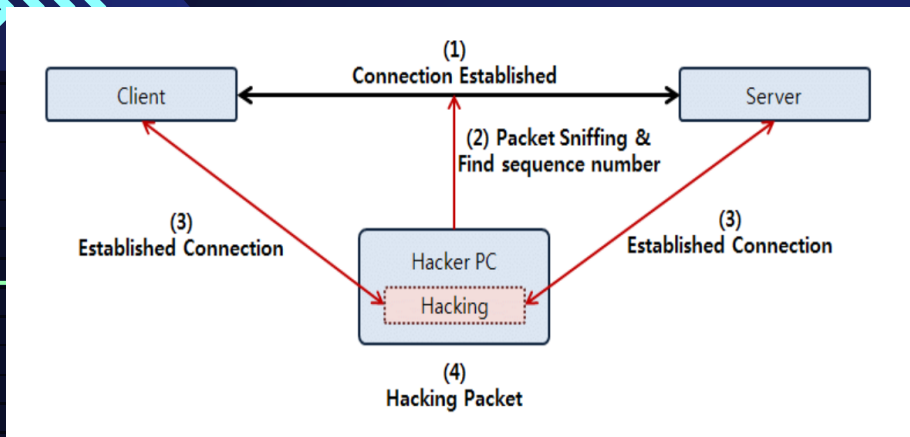
SYN-флуд
TCP-соединение устанавливается через трёхэтапное рукопожатие. Злоумышленник может отправить множество пакетов SYN, не реагируя на SYN/ACK от атакуемого хоста, что вызывает переполнение очереди прослушивания и приводит к сбою системы. В Linux очередь прослушивания для соединений TCP в состоянии SYN_RECV в ядрах 2.2 и старше по умолчанию равна 1024.



Эта команда устанавливает для `tcp_syncookies` значение 1, и ядро Linux будет игнорировать размер `tcp_max_syn_backlog`. Однако использование `tcp_syncookies` может иметь нежелательные побочные эффекты. Например, веб-сервер, который частично обрабатывает 1024 TCP-соединения, обычно отбрасывает новый пакет SYN при перегрузке. Это может привести новых клиентов к другому, менее загруженному веб-серверу, который может быстрее обработать их запрос. При включенных `syncookies` новые клиенты могут очень долго ждать ответа от перегруженного сервера.

Мы можем использовать `iptables` для защиты от SYN-флуда, ограничивая количество SYN-пакетов за определенный промежуток времени, как мы это делали для эхо-запросов ICMP:

```
root@router:~# iptables -A INPUT -p tcp --syn -m limit --limit 10/s -j ACCEPT
root@router:~# iptables -A INPUT -p tcp --syn -j DROP
```

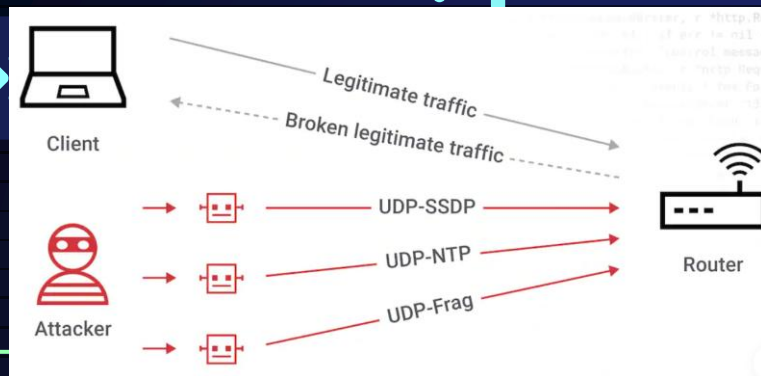


Land-атака

Land-атака — разрушительный метод, использующий программу `land.c` для отправки пакета SYN на хост с поддельным IP-адресом, равным IP-адресу назначения. Это приводит к сбоям в системах Unix, Windows и маршрутизаторах Cisco.

TCP Connection Hijacking

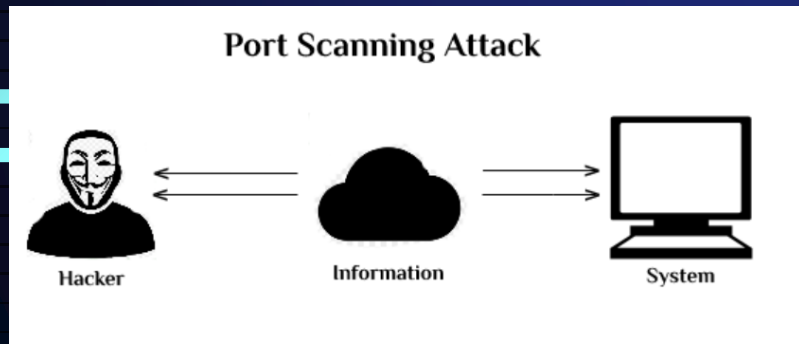
Атака типа «человек посередине» (TCP Connection Hijacking) позволяет злоумышленнику захватить контроль над TCP-соединением, нарушая синхронизацию номеров SEQ и ACK между узлами. Злоумышленник внедряет правильные команды в соединение, заставляя узлы отбрасывать пакеты друг друга.



UDP-атаки

UDP-флуд

UDP-флуд — это атака, при которой на атакуемую машину отправляется большое количество UDP-пакетов на случайные порты. Поскольку UDP не требует установления соединения, машина пытается определить приложение для каждого пакета. Если порт не используется, пакет отбрасывается. Нагрузка на жертву может привести к перегрузке и сбою системы.



Атаки сканирования портов

Злоумышленник обычно первым делом сканирует порты жертвы с помощью инструмента nmap, чтобы выявить открытые TCP и UDP порты и определить запущенные службы для последующей эксплуатации уязвимостей.